

REGULATORY RESPONSE REPORT · INTERNAL + COMPLIANCE

XimTier 규제 당국 대응 통합 보고서 컴플라이언스 입증 전략 + 기관별 제출 가이드

AI 기본법 · EU AI Act · 도메인 규제(금융위·식약처·개인정보위) 시대의 신뢰성 입증 매뉴얼 — 9개 핵심 기관
별 역할·제출 서류·절차·예상 기간·XimTier 대응 전략 통합

2026-05-14 · Gagahoho, Inc. · 내부 임원·법무·컴플라이언스 + IR/감사 대응용

요약 (Executive Summary)

본 보고서는 XimTier가 한국 AI 기본법(2026-01-22 시행) + EU AI Act(2026-08 완전 시행) + 도메인별 규제(금융위·식약처·개인정보위) 환경에서 (가) 어떻게 규제를 통과시킬지에 대한 내부 컴플라이언스 입정 전략과 (나) 각 규제·인증 기관에 무엇을 어떻게 제출할지에 대한 실무 가이드 를 통합한 매뉴얼이다.

대응 대상 기관 9개 정책 4 + 도메인 3 + 글로벌 2
핵심 인증 TTA CAT AI 신뢰성 인증 · 3~6개월
전체 로드맵 12-18개월 사전 준비 → 인증 → 도메인 인허가
XIMTIER 강점 XAI 4종 SHAP · Reverse What-If · 편향제어 · 감사로그

핵심 메시지 — 한국 AI 기본법의 4대 감사 지표(XAI · 반사실적 설명 · 편향성 제어 · 데이터 거버넌스)는 우연히도 **XimTier 아키텍처의 핵심 자산** 과 정확히 일치한다. 우리에게는 규제 비용이 아니라 경쟁 우위로 전환 가능한 자산 이다. 단, *내가 그렇다고 말하는 것*과 *제3자 기관이 인증서를 발급하는 것*은 다르다. 12~18개월 내 TTA CAT + 도메인 인허가를 확보해야 IR/세일즈에서 메시지가 진짜 무기가 된다.

목차

- 규제 환경 한눈에 — AI 기본법 시대의 4중 레이어
- 4대 감사 지표 vs XimTier 아키텍처 매핑
- 범부처 정책·기술 인증 기관 (과기부·TTA·NIA·KISA)
- 도메인 규제 기관 (금융위·감독원·식약처·개인정보위)
- 글로벌 규제 (EU AI Act·ISO/IEC 42001)
- 서비스 런칭 4단계 로드맵 (12~18개월)
- 기관별 제출 서류 목록 (체크리스트)
- 리스크 매트릭스 · 대응 우선순위
- 컴플라이언스 비용·기간 추정
- 다음 액션 (분기별)

1. 규제 환경 한눈에 — AI 기본법 시대의 4중 레이어

XimTier가 한국 시장에서 상용 서비스를 시작하려면 **4중 레이어의 규제** 를 동시에 통과해야 한다.

레이어	법령/표준	주관 기관	고위험 AI 위반 제재	적용 시점
L1	한국 AI 기본법	과학기술정보통신부	시정명령·과징금	2026-01-22 시행 중
L2	제3자 신뢰성 인증 (TTA CAT)	TTA	인증 미발급 시 정부 조달 배제	2026~ 단계 시행
L3	도메인 규제 (금융·의료·개인정보)	금융위/감독원·식약처·개인정보위	업무 정지·면허 박탈·형사 책임	도메인별 상시
L4	EU AI Act (글로벌 진출 시)	EU 회원국 · 한국 제3자 인증	최대 €35M 또는 매출 7%	2026-08 완전 시행

이중·삼중 적용 — 의료 금융 분야는 L1+L2+L3 동시 적용, EU 수출 시 L1+L2+L3+L4 모두 통과해야 함. 가장 보수적 기관의 기준이 사실상 사업 진입 장벽.

2. 4대 감사 지표 vs XimTier 아키텍처 매핑

AI 기본법 §13(설명 가능성) 및 EU AI Act §9(고위험 AI 의무)가 공통으로 요구하는 4가지 감사 지표를 XimTier 아키텍처와 매핑한다.

감사 지표 (Audit Point)	규제가 요구하는 것	XimTier 대응 자산	대응 등급
① 설명 가능성 (XAI)	블랙박스 모델이 아닌, 결과 도출 과정을 인간 언어로 소명	SHAP 기반 변수 기여도 분해 + 자동 보고서 생성	강함
② 반사실적 설명 (Reverse What-If)	결과를 바꾸기 위한 대안 경로(최소 변화량) 제시	Reverse What-If 엔진 — 핵심 차별점	강함
③ 편향성 제어	성별·연령·지역 등 특정 계층 차별 출력 방지	학습 데이터 그룹별 fairness 지표 모니터링 모듈 (구축 단계)	보강 필요
④ 데이터 거버넌스	수집·학습·폐기 전 과정 법적 절차 준수	온프레미스 100% + 감사 로그 + 데이터 라이프사이클 정책	정책 문서화 필요

XimTier 강점 — 한국 AI 기본법 4대 지표 중 ① + ② 두 가지는 **처음부터 아키텍처의 핵심** 이다. 이 두 가지를 다른 솔루션이 *나중에* 붙이려면 모델 재설계가 필요하지만 우리는 *기본값*이다.
보강 영역 — ③ 편향성 제어 모듈 + ④ 데이터 거버넌스 정책 문서가 *제3자 인증* 통과와 마지막 관문. 2026 H2까지 보강 필요.

3. 범부처 정책·기술 인증 기관

3-1. 과학기술정보통신부 (과기부) — 정책 총괄 L1

과학기술정보통신부 (MSIT) 정책 · 시행령 · 고위험 AI 분류	
핵심 역할	AI 기본법 시행령 관리, 고위험 AI 분류 기준 수립, ICT 규제 샌드박스 운영
XimTier 접점	(1) 고위험 AI 분류 신청 — 의료·금융·공공 도메인 적용 시 (2) 규제 샌드박스 — 신규 적용 분야에서 현행법 모호 시
제출 서류	고위험 AI 등록 신청서 · 시스템 카드(Model Card) · 영향평가 보고서 · 데이터셋 설명서
절차	온라인 신청 → 서면 심사 → 보완 (1차) → 현장 점검(필요 시) → 등록 결정

예상 기간	표준 등록: 2~3개월 · 규제 샌드박스: 3~6개월 (분기별 심사위 개최)
비용	등록 자체는 무상 · 컨설팅·범무 비용 별도
XimTier 전략	의료/금융 도메인 본격 진입 전 샌드박스 신청으로 규제 해석 사전 확보 · 첫 PoC 완료(2026 Q3) 이후 즉시 신청 권장

3-2. TTA (한국정보통신기술협회) — AI 신뢰성 인증(CAT) L2 핵심

TTA — Telecommunications Technology AssociationAI 신뢰성 인증 (CAT) · 제3자 기술 인증	
핵심 역할	AI 신뢰성 인증 (CAT) 발급 — XAI·공정성·안전성·견고성 기술 표준 적합성 평가
XimTier 접점	가장 중요한 단일 인증 — IR/세일즈·정부 조달·도메인 허가 모두에서 핵심 신뢰 마커
인증 항목	설명 가능성(XAI) · 공정성(Fairness) · 견고성(Robustness) · 안전성(Safety) · 투명성(Transparency)
제출 서류	(1) 신청서 (2) AI 시스템 명세서 (모델 카드) (3) 학습 데이터셋 설명서 (데이터 카드) (4) XAI 설명 모듈 결과물 샘플 (5) 공정성 평가 결과 (6) 견고성 테스트 보고서 (적대적 입력 대응) (7) 보안·개인정보 보호 정책 (8) 운영 매뉴얼
절차	① 신청 접수 → ② 서면 심사 → ③ 현장 평가 (시연 + 코드 부분 검증) → ④ 보완 요청 → ⑤ 인증 위원회 심의 → ⑥ 인증서 발급
예상 기간	3~6개월 (보완 요청 횟수에 따라 가변)
비용	약 2,000만~5,000만원 (시스템 규모·인증 범위에 따라)
XimTier 전략	2026 Q3~Q4 신청 → 2027 Q1~Q2 인증 획득 목표. IR Deck에 인증 진행 마일스톤 명시 → "TTA CAT 신청 중" 시점부터 신뢰도 마커 사용 가능

3-3. NIA (한국지능정보사회진흥원) — 공공 확산 L1

NIA — National Information Society Agency공공기관 도입 가이드 · 윤리 영향 평가	
핵심 역할	공공기관 AI 도입 가이드라인 개발, AI 윤리 영향 평가 지원, 공공 데이터 매칭
XimTier 접점	(1) 공공기관 영업 시 NIA 가이드라인 적합성 자체 점검 (2) AI 윤리 영향 평가 를 자발적으로 받아 신뢰 마커 확보 (3) 공공 SaaS 마켓플레이스(디지털서비스개발형 플랫폼) 등록
제출 서류	윤리 영향 평가 신청서 + 시스템 설명서 + 이해관계자 분석 + 영향 평가 자체 보고서
절차	온라인 신청 → 자체 평가 보고서 제출 → NIA 자문위원 검토 → 권고안 회신
예상 기간	2~3개월
비용	무상
XimTier 전략	공공기관 영업 본격화(2027 H1) 전 NIA 윤리 영향 평가 완료. 결과를 IR 자료에 활용

3-4. KISA (한국인터넷진흥원) — 보안·데이터 L1

KISA — Korea Internet & Security AgencyAI 보안 · 개인정보 비식별화 평가	
핵심 역할	AI 모델 보안성 검토, 학습 데이터 내 개인정보 비식별화 적정성 평가, 정보보호 관리체계(ISMS) 인증
XimTier 접점	(1) ISMS-P 인증 — 금융·의료 도메인 진입 필수 (2) 비식별 적정성 평가 — 고객 데이터 학습/PoC 시
제출 서류	ISMS-P: 정보보호 정책서 · 위험 분석 보고서 · 운영 절차서 · 감사 로그 · 사고 대응 매뉴얼 (총 80~120개 항목)
절차	① 자체 점검 → ② 신청 → ③ 1차 심사 (서면) → ④ 2차 심사 (현장) → ⑤ 보완 → ⑥ 인증위원회 → ⑦ 인증 발급
예상 기간	ISMS-P: 6~9개월 (첫 인증) · 비식별 평가: 1~2개월
비용	ISMS-P: 약 3,000만~6,000만원 (조직 규모별) · 비식별 평가: 무상
XimTier 전략	금융권 PoC 본격화 전 ISMS-P 필수. 2026 H2~2027 H1 진행. 우리 "온프레미스 100%" 메시지가 ISMS-P 통과 난이도를 낮춤

4. 도메인 규제 기관

4-1. 금융위원회 / 금융감독원 — 신용평가·자산관리 AI L3

금융위원회 (FSC) · 금융감독원 (FSS)AI 신용평가·자산관리 알고리즘 투명성	
핵심 임무	AI 신용평가·자산관리 모델의 알고리즘 투명성 심사, 금융소비자보호법상 '설명 의무' 준수 여부 점검
특이사항	Reverse What-If를 통한 대충 거절 사유 소명 가능 여부를 중점 확인 — XimTier의 핵심 기능과 정확히 일치
제출 서류	(1) AI 신용평가 모델 검증 보고서 (2) 설명 가능성 입증서 (SHAP·반사실적 설명) (3) 모형 검증위원회 보고서 (4) 데이터 거버넌스 정책 (5) 운영 위험 평가 (6) 사후 모니터링 계획
절차	① 금융사 사전 신고 → ② FSS 모형 검증 → ③ 현장 점검(거절·차별 사례 5건 이상 샘플 검증) → ④ 보완 → ⑤ 사용 승인
예상 기간	6~12개월 (금융사 사이클이 김)
비용	승인 자체는 무상 · 모형 검증 컨설팅 5,000만~2억
XimTier 전략	KB인베·신한벤처 IR 미팅에서 "우리는 FSS 모형 검증을 정확히 통과하도록 설계됨" 메시지 강조. KB Starters 오픈이노베이션 시 모형 검증 PoC 제안

4-2. 식품의약품안전처 — AI 의료기기(SaMD) L3

식품의약품안전처 (MFDS)AI 의료기기 인허가 · 임상 유효성	
핵심 임무	AI 의료기기(Software as a Medical Device · SaMD) 인허가 및 임상적 유효성 평가

특이사항	AI 진단 결과의 판독 근거(Heatmap/SHAP 등) 시각화 + 의사의 최종 판단 지원 능력 필수
제출 서류	(1) 의료기기 제조 허가 신청서 (2) GMP 적합 인증서 (3) 임상시험 결과 보고서 (4) 기술문서 (의도된 사용·성능·임상 평가) (5) 위험관리 보고서 (6) 사이버 보안 평가 (7) 설명 가능성 입증 자료 — XimTier 강점
절차	① 사전 상담 → ② 임상시험 계획 승인 → ③ 임상시험 실시 → ④ 허가 신청 → ⑤ 심사 → ⑥ 보완 → ⑦ 허가
예상 기간	12~24개월 (임상 포함 시 가장 김)
비용	임상 포함 5억~수십억 (영상의학 SaMD 기준)
XimTier 전략	의료 도메인은 *직접 SaMD 등록보다 대형 병원과 공동 R&D*가 효율적. 첫 케이스는 의료기기가 아닌 *병원 경영 최적화*로 우회 진입

4-3. 개인정보보호위원회 — 자동화된 결정 L3

개인정보보호위원회 (PIPC) 자동 의사결정 · 정보주체 권리	
핵심 임무	자동화된 결정(Automated Decision-making)에 대한 정보주체의 권리 보장 심사. 개인정보보호법 §37의2 적용
특이사항	이용자가 AI 결정에 이의 제기 시 기업이 적절한 설명을 제공할 시스템 을 갖췄는지 평가
제출 서류	(1) 자동 결정 시스템 설명서 (2) 이용자 통지·설명 절차 (3) 이의제기 처리 절차 (4) 설명 가능성 기술 입증 자료 (5) 개인정보 영향평가서(공공기관 의무)
절차	사전 컨설팅 → 시정명령(문제 발견 시) 또는 침해사고 신고 시 조사
예상 기간	사전 컨설팅: 1~2개월 · 조사 발생 시 6개월+
XimTier 전략	고객사가 PIPC 점검 받을 때 "우리 시스템이 이미 설명 가능성을 보장"한다는 입증 자료를 "고객사가 그대로 제출" 가능하도록 표준 양식 사전 준비

5. 글로벌 규제 — EU AI Act · ISO/IEC 42001

5-1. EU AI Act (2026-08 완전 시행) L4

EU AI Act 고위험 AI · €35M 벌금 · 글로벌 진출 필수	
관련 조항	§9 위험관리시스템 · §10 데이터·데이터 거버넌스 · §11 기술문서 · §12 로깅 · §13 투명성·이용자 정보 · §14 인적 감독 · §15 정확성·견고성·사이버보안
고위험 AI 분류	교육·교육·신용평가·법 집행·의료·핵심 인프라 — XimTier 주요 ICP가 대부분 포함
제출 서류	(1) 적합성 평가 (Conformity Assessment) (2) EU 선언문 (Declaration of Conformity) (3) CE 마킹 (4) 기술문서 (Annex IV) (5) 위험관리·데이터 거버넌스·로깅·투명성·인적감독·견고성 7대 영역 입증 (6) Post-Market Monitoring Plan
절차	유럽 회원국 Notified Body 또는 한국 협력 인증기관 → 적합성 평가 → CE 마킹
예상 기간	6~12개월
벌금	최대 €35M (약 ₩520억) 또는 글로벌 매출 7% 중 큰 금액
XimTier 전략	국내 시장 안착(2026 H2~2027 H1) 후 2027 H2부터 본격 준비. 한국 TTA CAT 인증을 EU 인증의 사전 단계 로 활용 (양자 협력 진행 중)

5-2. ISO/IEC 42001 — AI 경영시스템

ISO/IEC 42001 AI 경영시스템 국제 표준	
핵심 임무	AI 경영시스템(AIMS) 국제 표준 — 위험관리·문서화·지속개선 체계
제출 서류	AI 정책 · 위험 분석 · 통제 절차 · 내부 감사 보고서 · 경영검토 회의록
절차	1단계 심사(문서) → 2단계 심사(현장) → 인증 → 매년 사후 심사 → 3년마다 갱신
예상 기간	첫 인증 9~12개월 · 갱신 3개월
비용	약 3,000만~8,000만원 (조직 규모별)
XimTier 전략	EU/일본/싱가포르 진출 시 필수. ISMS-P 통합 운영하면 비용·기간 절감 가능

6. 서비스 런칭 4단계 로드맵 (12~18개월)

STEP 1 · 0~3M 사전 준비 AI 윤리 가이드라인 수립 · XAI 모듈 아키텍처 설계 · 편향성 제어 모듈 보강 · 데이터 거버넌스 정책 문서화
STEP 2 · 3~9M 기술 인증 TTA CAT 신청 → 서면·현장 심사 → 인증 획득 · KISA ISMS-P 병행 · NIA 윤리 영향평가
STEP 3 · 6~12M 규제 샌드박스 과기부 ICT 샌드박스 신청 (신규 도메인 적용 시) · 규제 해석 사전 확보 · PoC 보호막 확보
STEP 4 · 9~18M 도메인 인허가 금융위/FSS 모형 검증 (금융사 PoC 시) · 식약처 SaMD (의료기기 시) · 개인정보보호위 컨설팅 (자동 결정 적용 시)
병렬 처리가 핵심 — 위 4단계는 순차가 아닌 병렬 실행 가능 . STEP 1 종료 시점에 STEP 2와 STEP 3 동시 진행 가능. 실제 소요는 12~18개월.

7. 기관별 제출 서류 체크리스트

기관	핵심 제출 서류	난이도	현재 보유
과기부	고위험 AI 등록 신청서 · 시스템 카드 · 영향평가	중	부분
TTA CAT	모델 카드 · 데이터 카드 · XAI 샘플 · 공정성 평가 · 견고성 테스트 · 보안 정책 · 운영 매뉴얼	높음	부분 (XAI 강함)
NIA	윤리 영향 평가 자체 보고서	낮음	미보유
KISA ISMS-P	정보보호 정책 · 위험 분석 · 운영 절차 · 사고 대응 (80~120 항목)	높음	미보유
금융위/FSS	모델 검증 보고서 · 설명 가능성 입증 · 모형 검증위 보고서	매우 높음	부분
식약처	임상 결과 · 기술문서 · 위험관리 · 사이버보안	매우 높음	미보유 (의료 직접 진입 시)
개인정보위	자동 결정 시스템 설명서 · 이익제기 처리	중	미보유
EU AI Act	적합성 평가 · 기술문서 (Annex IV) · CE 마킹	매우 높음	미보유
ISO/IEC 42001	AI 정책 · 위험 분석 · 통제 절차 · 감사 보고서	높음	미보유

8. 리스크 매트릭스 · 대응 우선순위

인증/허가 미확보가 사업에 미치는 영향을 *발생 확률* x *영향* 매트릭스로 평가한다.

리스크	발생 확률	영향도	대응 우선순위
금융권 PoC 시 FSS 모형 검증 통과 실패	높음	매우 큼	P0 — TTA CAT + 모형 검증 사전 준비
개인정보 침해 사고 → 개인정보위 조사	중간	매우 큼	P0 — 오피레미스 + 감사 로그 + ISMS-P
EU 진출 시 AI Act 부적합 → €35M 벌금	낮음 (현 단계)	치명적	P1 — 2027 H2부터 준비
TTA CAT 미인증 → 정부 조달 배제	중간	큼	P0 — 2026 Q3 신청
NIA 윤리 영향 평가 부정 의견	낮음	중간	P2 — 공공 영업 시점에 맞춰
식약처 SaMD 미허가 → 의료 직접 진입 불가	높음	큼	P2 — 의료는 *경영 최적화*로 우회 진입

9. 컴플라이언스 비용·기간 추정

항목	기간	비용 (직접)	비용 (간접·인건비)	비고
TTA CAT 인증	3~6개월	₩2,000~5,000만	₩5,000만~1억	2026 Q3~Q4 신청 권장
KISA ISMS-P	6~9개월	₩3,000~6,000만	₩1억~1.5억	금융권 PoC 전 필수
NIA 윤리 영향 평가	2~3개월	무상	₩2,000만~3,000만	공공 영업 전
과기부 ICT 샌드박스	3~6개월	무상	₩3,000만~5,000만	신규 도메인 시
금융위/FSS 모형 검증	6~12개월	무상	₩5,000만~2억	금융사 PoC 시
ISO/IEC 42001	9~12개월	₩3,000~8,000만	₩1억	해외 진출 전
EU AI Act 적합성	6~12개월	₩5,000만~2억	₩2억~5억	2027 H2+
총합 (한국 시장)	12~18개월	₩1억~2.5억	₩3.5억~6억	국내 진출용
총합 (글로벌)	24~30개월	₩2억~5억	₩7억~12억	EU/일본 포함

비용은 사실상 "Pre-Seed 시드 라운드 한 번" — 한국 컴플라이언스 총비용 ₩4.5~8.5억은 Seed 라운드(₩10~15억) 한 번으로 모두 커버 가능. 이 투자가 경쟁 우위로 직접 전환 되는 영역.

10. 다음 액션 (분기별)

시기	액션	담당	산출물
2026 Q2	TTA CAT 사전 컨설팅 신청 · 시스템 카드/데이터 카드 1.0 작성	CTO + 외부 컴플라이언스 자문	시스템 카드 v1.0
2026 Q3	TTA CAT 정식 신청 · KISA ISMS-P 사전 진단 · NIA 윤리 영향 평가 신청	CTO · CISO	3개 신청서
2026 Q3	과기부 ICT 샌드박스 신청 (Reverse What-If 신규 적용 분야 보호)	CEO · 법무	샌드박스 승인
2026 Q4	TTA CAT 현장 평가 · 편향성 제어 모듈 v1.0 출시	CTO	편향성 모듈
2027 Q1	TTA CAT 인증서 발급 · KISA ISMS-P 1차 심사	CTO · CISO	TTA CAT 인증서
2027 Q2	금융위/FSS 모형 검증 사전 협의 (KB·신한 PoC 연계)	CEO · 금융 도메인 책임자	모형 검증 계획
2027 H2	ISO/IEC 42001 신청 · EU AI Act 적합성 사전 평가	CTO · 글로벌 사업 책임자	EU CE 마킹 준비

핵심 우선순위 P0 — ① TTA CAT 인증 (2026 Q3 신청) 가 모든 후속 인증·세일즈·IR의 신뢰 마커. 이 한 건이 가장 중요.
차순위 P1 — KISA ISMS-P (금융권 PoC의 전제 조건).

11. 결론

규제는 비용이 아니라 자산이다. 한국 AI 기본법 §13의 4대 감사 지표(XAI · Reverse What-If · 편향성 · 데이터 거버넌스) 중 ①②는 XimTier 아키텍처의 *기본값*이다. 우리에게만 규제 시행이 *위협*이 아니라 *증명 가능한 솔루션의 시장 가치를 끌어올리는 트리거*다.

단, "내가 그렇다고 말하는 것"과 "제3자 기관이 인증서를 발급하는 것"은 다르다. TTA CAT 인증 + KISA ISMS-P 두 가지는 12~18개월 안에 반드시 확보해야 한다. 이것이 없으면 IR/세일즈 메시지가 *마케팅 카피*에 머무르고, 있으면 *제3자 보증된 차별점*이 된다.

출처: AI_Framework_Act_Key_Institutions.md (2026-05), 한국 AI 기본법 (2026-01-22 시행), EU AI Act (Regulation 2024/1689), ISO/IEC 42001:2023, TTA AI 신뢰성 인증 가이드, KISA ISMS-P 인증 안내서, 금융감독원 AI 모형 가이드라인, 식약처 SaMD 가이드, 개인정보보호위원회 자동 결정 안내. 본 보고서는 내부 임원·법무·컴플라이언스 + IR/감사 대응용. 시일·비용은 추정치이며 실제 신청 시 각 기관 최신 안내 확인 필요.